Codice Python sicuro
Buone pratiche e strumenti di analisi

“Come dormire sonni più sereni, scrivendo codice più sicuro…”

Matteo Vitali (trotto)

Who Am I

Backend Developer and DevOps



- **Sociologist by training** and passionate about computer science.
- **Gnu/Linux** user, free and **open source** software advocate.
- Develop in **Python** and **Django** is my favorite way to build things.
- **Python Marche** founder and co-organizer
  >> https://marche.python.it



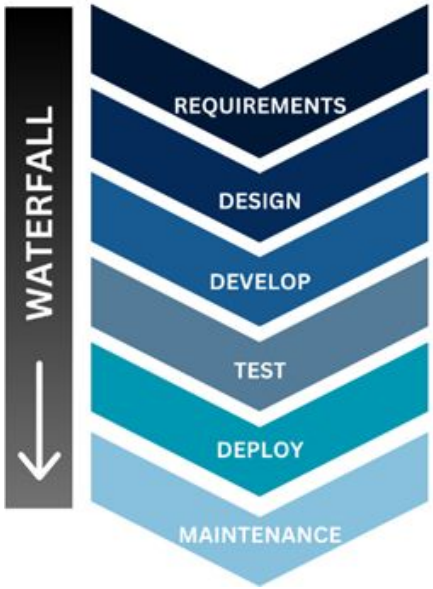
Agenda

1. Breve storia dell'introduzione della sicurezza nel SDLC (personale rivisitazione)
2. Buone pratiche e strumenti di analisi
3. [Demo Live] "Hack your own code", vediamo insieme alcune buone (e cattive) pratiche all'opera

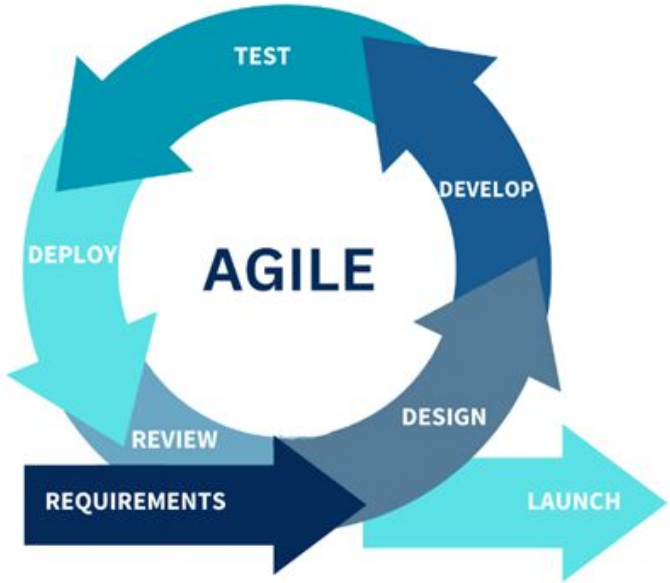
“Once upon a time…”

“Once upon a time…”

```
# Waterfall VS Agile
```



VS



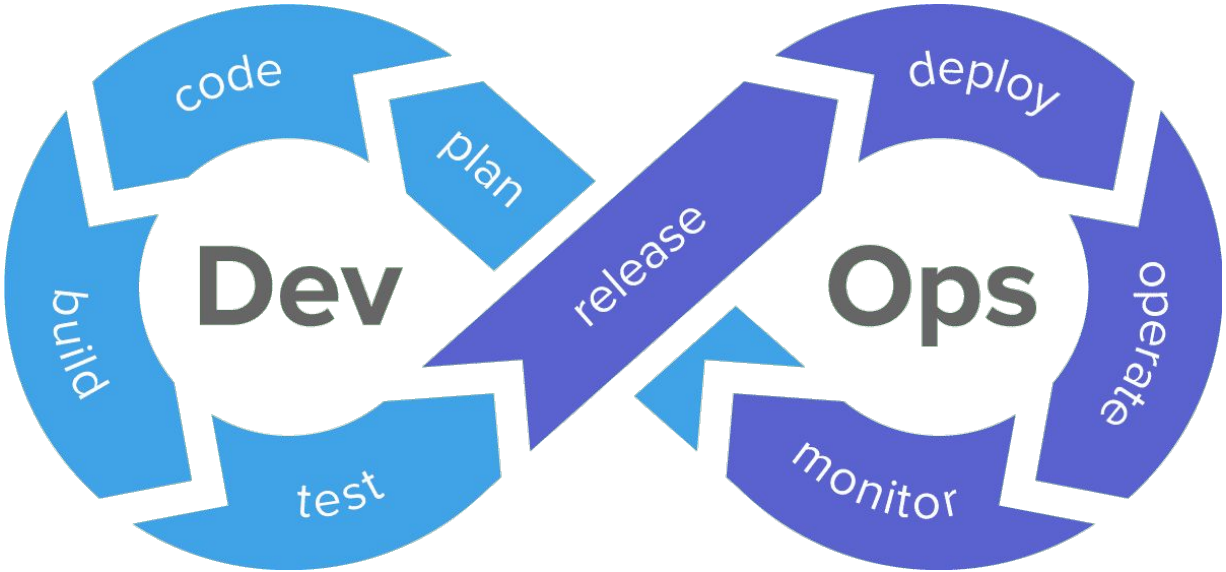
“Where is operations??”

```
# Operations?!?!?!
```



Chi ha parlato di Software Development Life Cycle?

```
# DevOps!!! (una moderna metodologia per il SDLC)
```



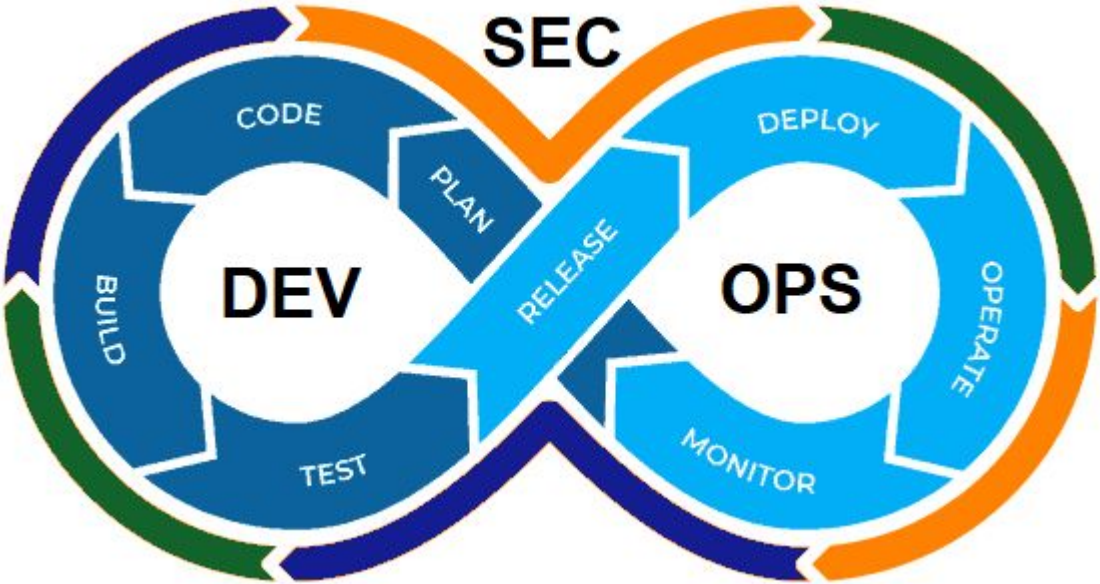
“Where is security??”

```
# Sicurezza?!?!?!
```



DevSecOps

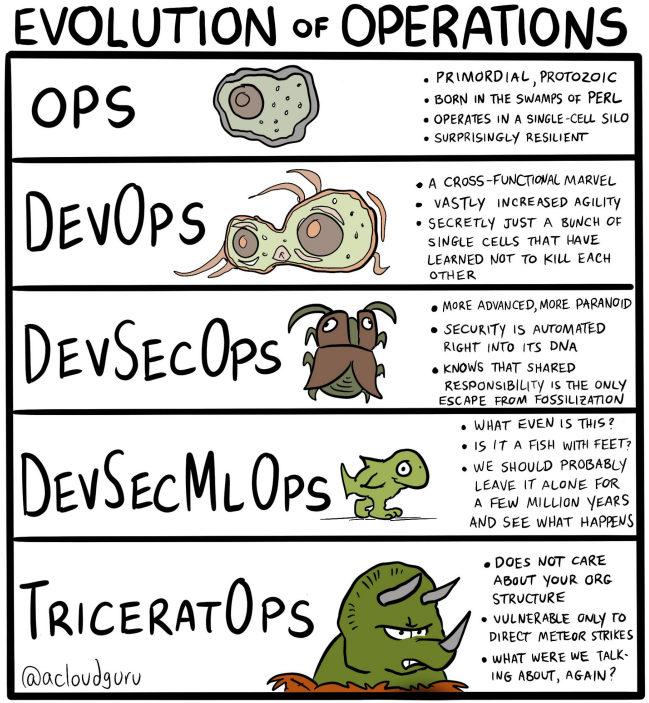
```
# Una moderna metodologia per l'introduzione della sicurezza nel SDLC
```



https://www.devsecops.org

DevSec*Ops

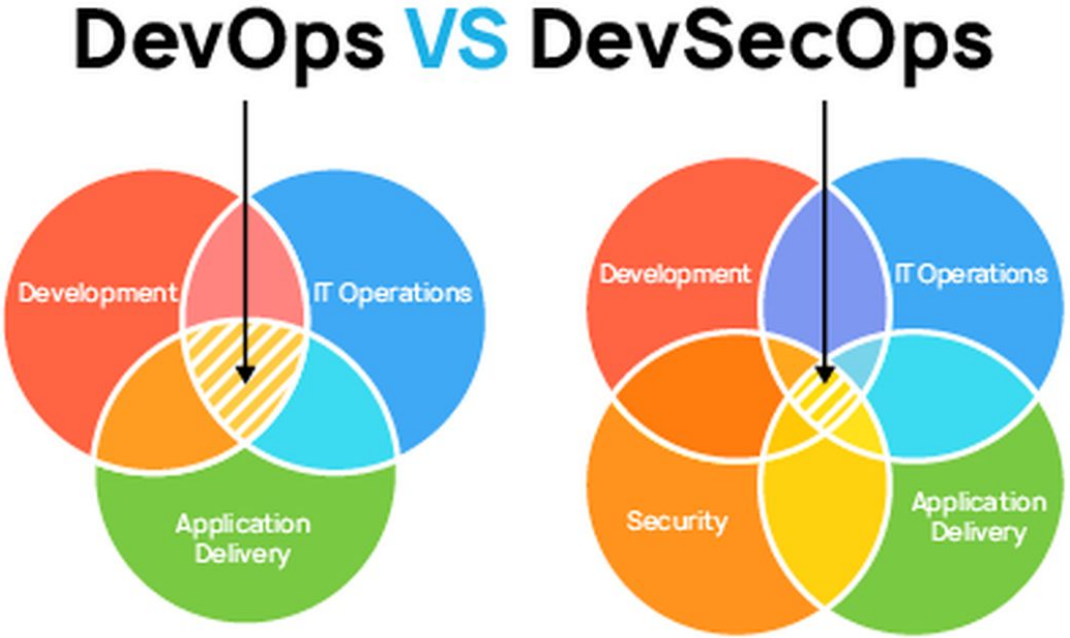
```
# Evoluzione della sicurezza nel SDLC
```




Rai 1 HD
No sir, it was just a little trolling

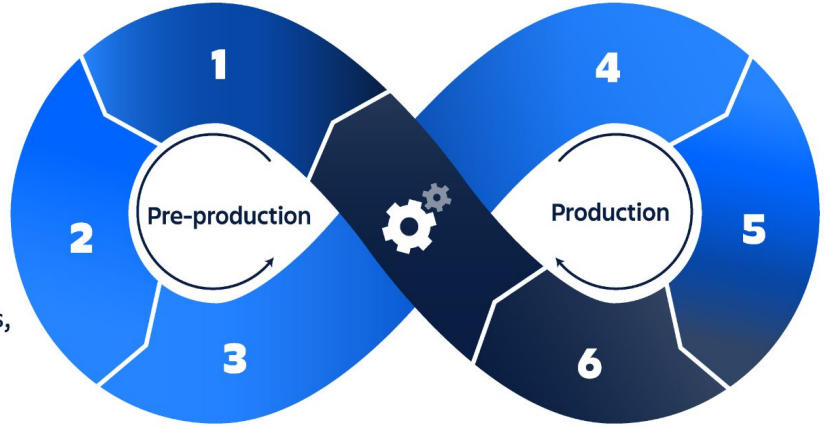
Devops VS DevSecOps

```
# Sicurezza nel SDLC
```



DevSecOps

```
# Potenziali step e applicazioni nel SDLC
```



Plan
(PRE-PRODUCTION)
Threat modeling, change impact analysis

Deploy
(PRODUCTION)
Access and configuration management, chaos engineering, pen testing

Build
(PRE-PRODUCTION)
Pre-commit hooks, software composition analysis, SAST, code review, container security, vulnerability scanning, DAST

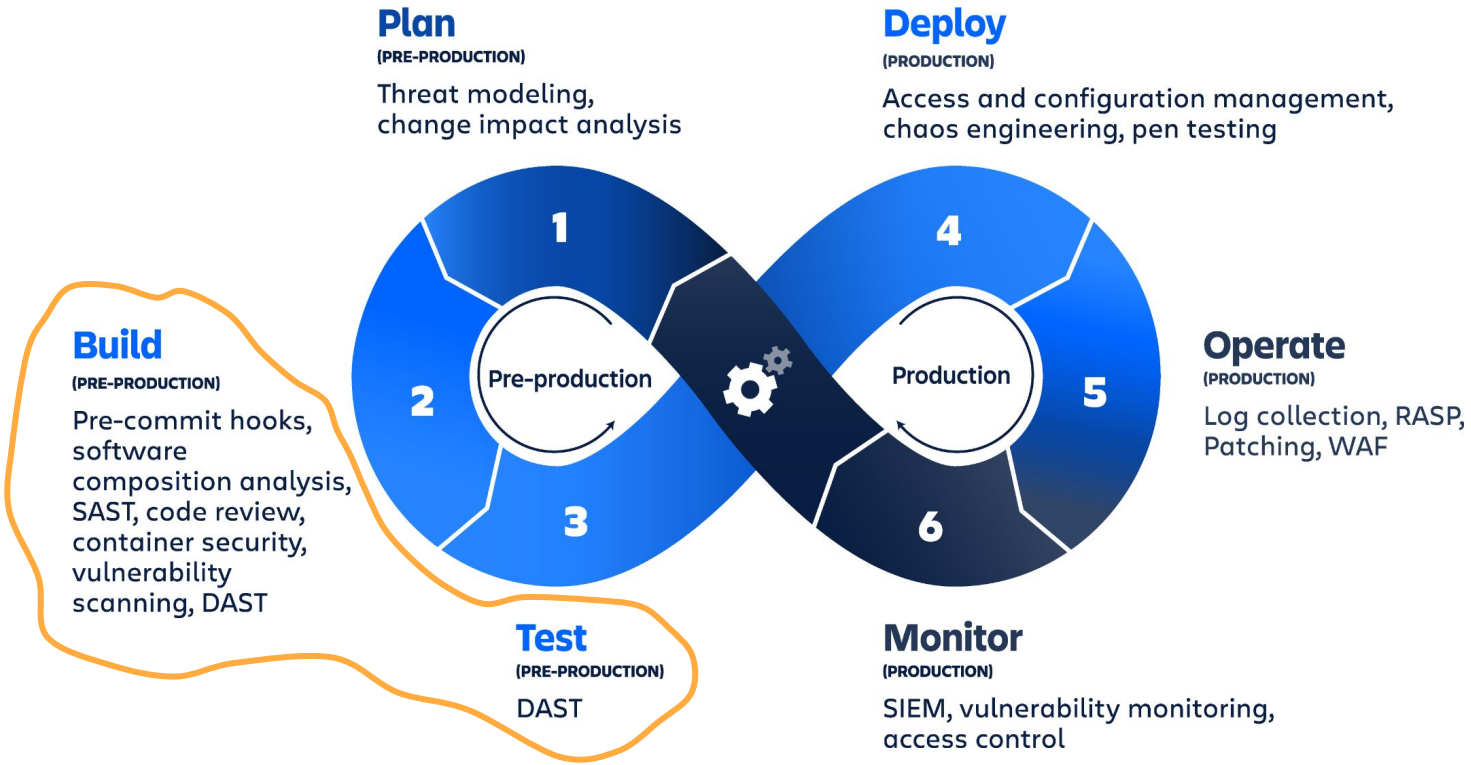
Operate
(PRODUCTION)
Log collection, RASP, Patching, WAF

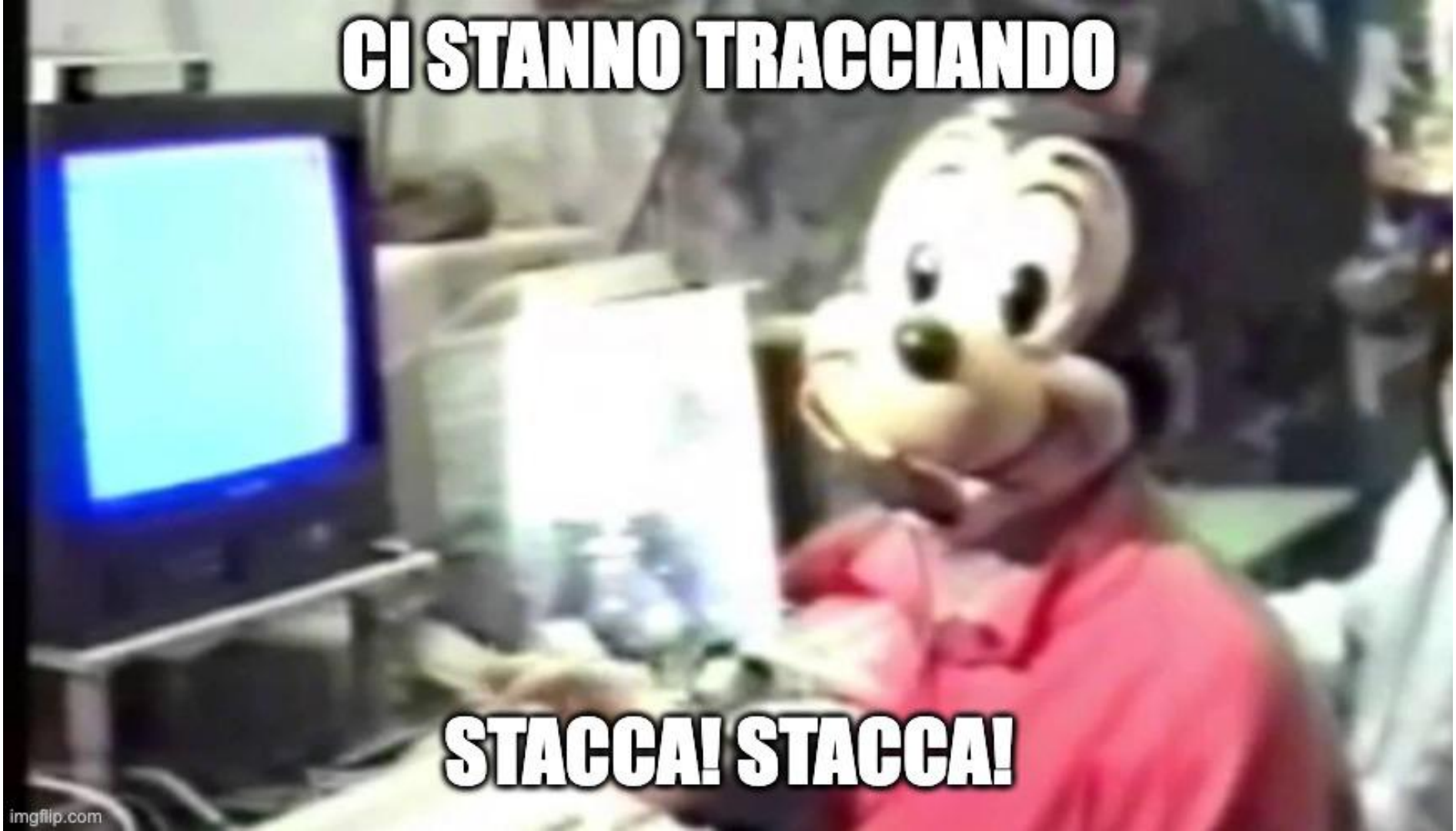
Test
(PRE-PRODUCTION)
DAST

Monitor
(PRODUCTION)
SIEM, vulnerability monitoring, access control

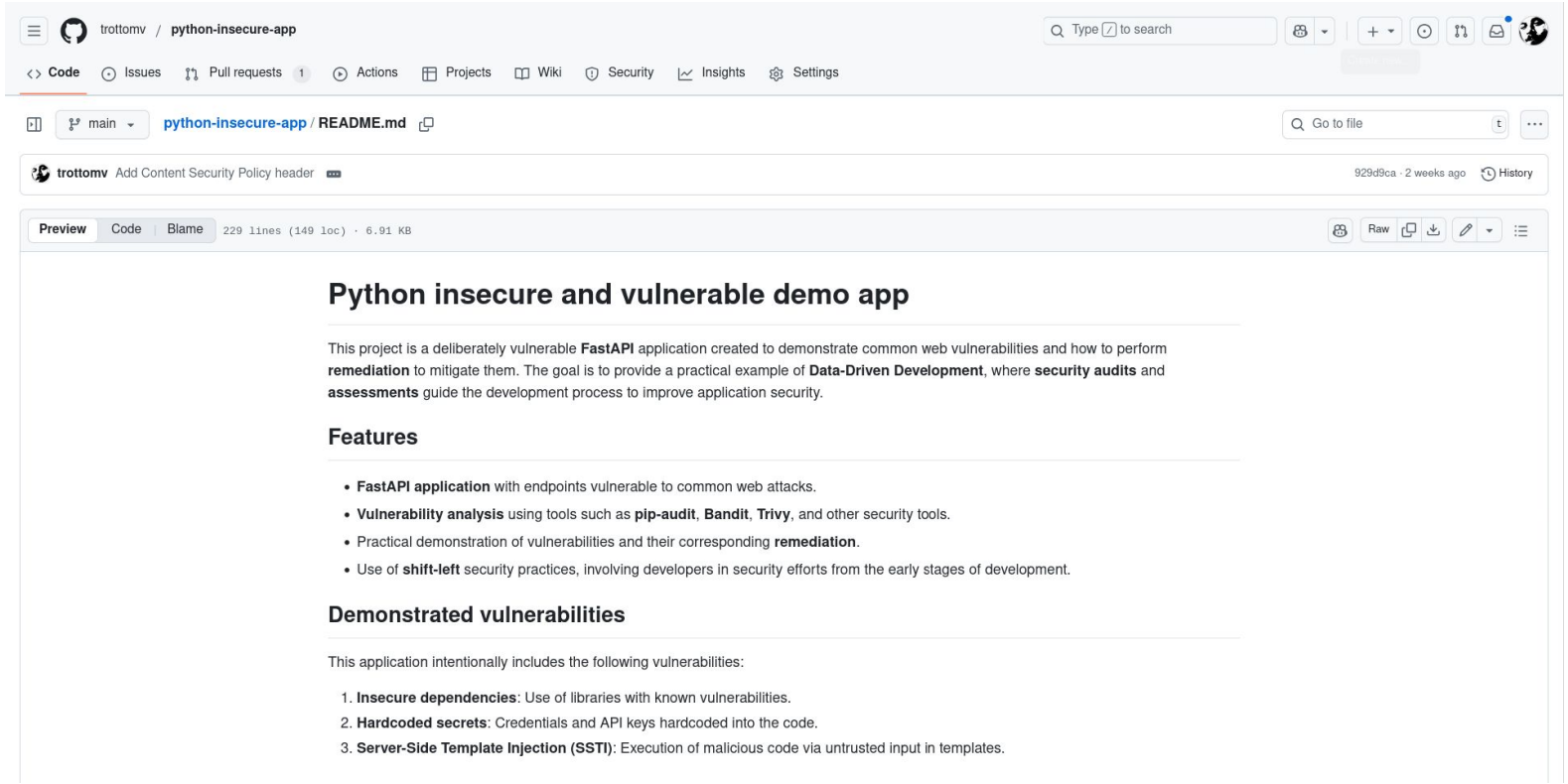
DevSecOps

```
# Potenziali step e applicazioni nel SDLC
```




CI STANNO TRACCIANDO
STACCA! STACCA!
imgflip.com

Python insecure and vulnerable demo app



https://github.com/trottomv/python-insecure-app

Python insecure and vulnerable demo app

README.md

A deliberately vulnerable **FastAPI** application created to **demonstrate common web vulnerabilities** and how to **perform remediation** to mitigate them. The goal is to provide a practical example of **Data-Driven Development**, where **security audits and assessments** guide the development process to improve application security.

This application intentionally includes the following vulnerabilities:

- **Insecure dependencies**: Use of libraries with known vulnerabilities.
- **Hardcoded secrets**: Credentials and API keys hardcoded into the code.
- **Server-Side Template Injection (SSTI)**: Execution of malicious code via untrusted input in templates.

https://github.com/trottomv/python-insecure-app

Python insecure and vulnerable demo app

```
# Strumenti di Analisi
```

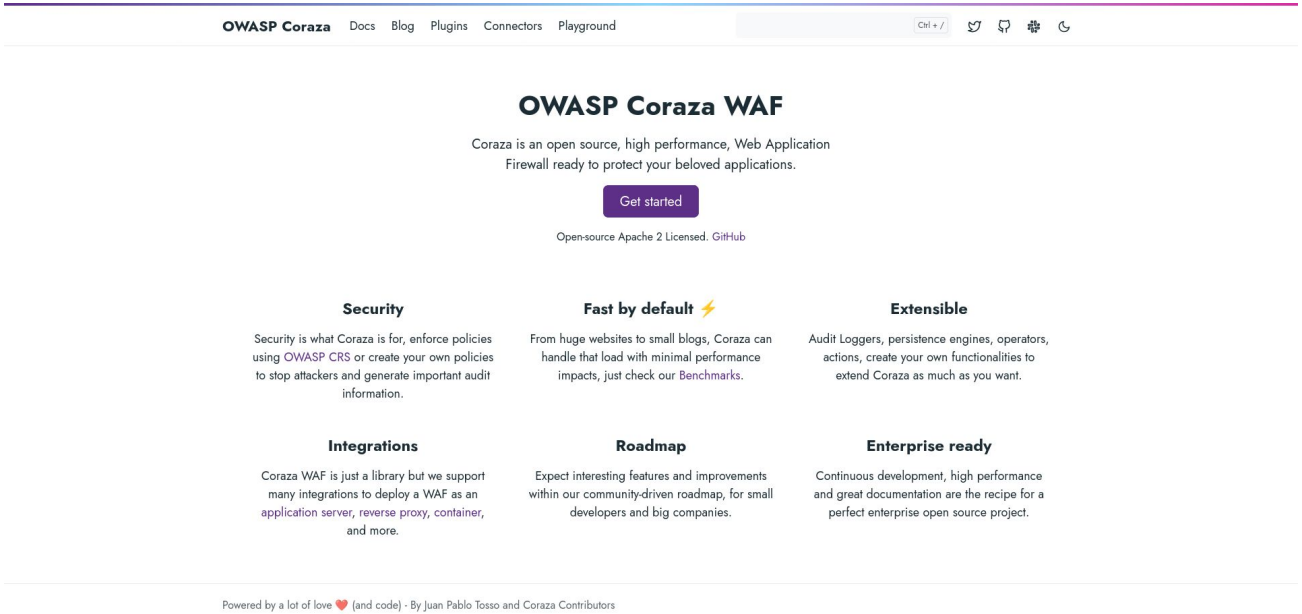
- [*SCA* - **pip-audit**] Controllo delle librerie e dipendenze di terze parti
- [*SAST* - **bandit**] Controllo delle comuni issue di sicurezza sul codice Python
- [*DAST* - **schemathesis** / hypothesis] Fuzzy API tests
- [*VA* - **Trivy** - Aquasec] Artifact Vulnerability Assessment
- [*PenTest* - **OWASP ZAP]** Zed Attack Proxy by OWASP for penetration tests
- Simulazione di un attacco **“Command line injection and RCE”**
- … **Remediations** “hands on”

https://github.com/trottomv/python-insecure-app

Prima di iniziare la Demo...

OWASP Coraza Web Application Firewall

```
# Remote self protection
```



https://coraza.io/

Demo time!

https://github.com/trottomv/python-insecure-app

Considerazioni Finali 🤔...

Takeaways ...

🤔

- Il **codice funzionante** non significa necessariamente **codice sicuro**
- **Approccio artigianale**: tool open source, non soluzioni enterprise, cuciti su misura su un caso d’uso Python
- **Dagli script locali alla pipeline il passo è breve**: automatizzare il workflow richiede più disciplina che complessità
- **I tool non sono infallibili**: aiutano a scovare findings, ma non sempre li trovano tutti, e possono diventare essi stessi un vettore di attacco alla supply chain (zero trust!)


CAN'T SLEEP
HACKERS WILL GET ME
imgflip.com

Thank you!... Questions?

Leave me your feedback!



/trottomv



/matteovitali



https://fosstodon.org/@trotto

https://trottomv.me